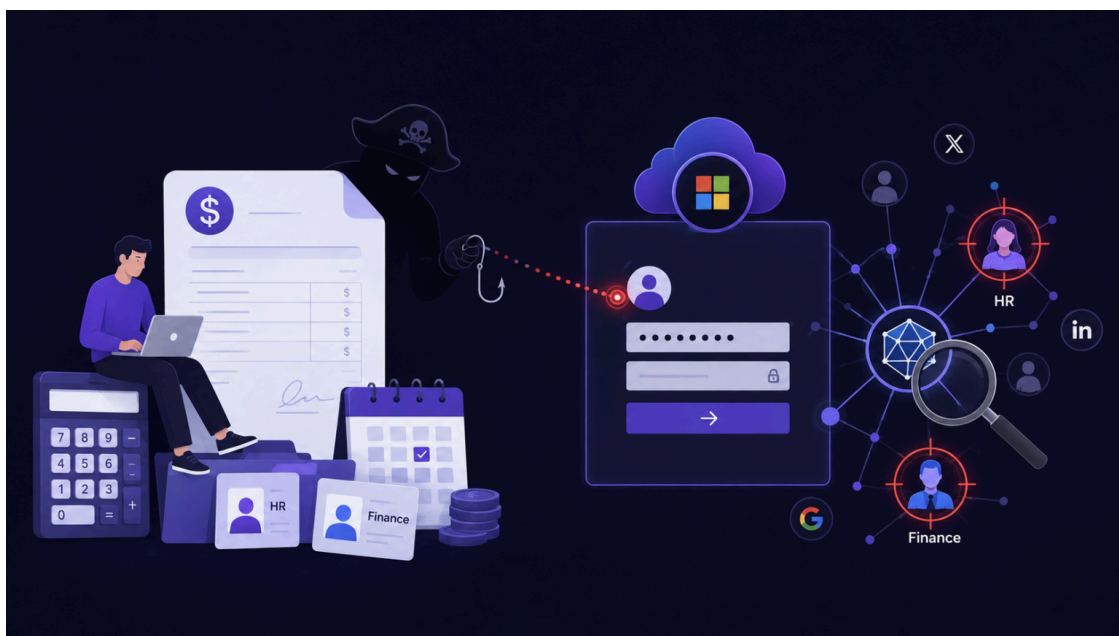




Кибербезопасность | Новости Кибербезопасности | Microsoft

Злоумышленники используют Microsoft Graph для поиска сотрудников отдела кадров и бухгалтерии после взлома аккаунта



Автор **Маюра Катир**

10 августа 2026 года

Широко распространенная фишинговая операция, в ходе которой злоумышленники получают доступ к учетным записям Microsoft 365 через инфраструктуру типа

платы, финансы, кадровую политику, льготы, счета и банковские операции.



Эта активность тесно связана с кластером «Payroll Pirates» от Microsoft, отслеживаемым как Storm-2755.

Исследователи также обнаружили сходство с активностью, ранее задокументированной Security Risk Advisors, что указывает на то, что целевая аудитория этой операции может быть шире, чем предполагалось изначально.

Первоначальный доступ осуществляется через фишинговые письма на тему голосовой почты, которые маскируются под автоматические уведомления о звонках.

В сообщениях используется фирменный стиль Microsoft, вымышленные данные о звонящем и приманка «ОТКРЫТЬ ПОРТАЛ ГОЛОСОВОЙ ПОЧТЫ [организации]», чтобы создать ощущение срочности.

При переходе по ссылке жертва попадает в многоуровневую цепочку перенаправлений, которая использует легитимные редиректоры Google Meet, рекламную инфраструктуру Google, трекары кликов Campaign Manager и контент, размещенный на Amazon S3, прежде чем перейти на контролируемые злоумышленниками **фишинговые домены AiTM**.

Фишинговый набор имитирует легитимный процесс аутентификации Microsoft в режиме реального времени, а не показывает статичную страницу для сбора учетных данных.

В результате

..php.ssf.

артефакты аутентификации и данные сеанса, возвращаемые при обратном вызове OAuth.



Таким образом, традиционная многофакторная аутентификация становится неэффективной, если пользователей обманом заставляют проходить аутентификацию через вредоносный обратный прокси-сервер.

Прежде чем приступить к проксированному входу в систему, инфраструктура собирает данные о посетителях через конечную точку PHP. JavaScript собирает информацию о браузере, операционной системе, аппаратном обеспечении, WebGL, языке, разрешении экрана, файлах cookie и WebDriver.

Кроме того, он запрашивает общедоступную службу геолокации и сохраняет код страны жертвы в файле cookie.

Эти меры, вероятно, помогают операторам фильтровать исследователей в области кибербезопасности и автоматизированные системы анализа при выборе географически правдоподобной прокси-инфраструктуры для последующего доступа.

Исследователи из Arctic Wolf сообщили, что кампания, развернутая в Северной Америке и Европе, была нацелена на организации в сфере здравоохранения, образования, производства, государственного управления и профессиональных услуг.

После захвата учетной записи злоумышленники используют постоянно меняющиеся резидентные прокси, чтобы вредоносные попытки входа в Microsoft 365 выглядели как обычный пользовательский трафик.

Arctic Wolf зафиксировал подозрительную активность при аутентификации в OfficeHome вскоре после того, как жертвы посещали фишинговые страницы. Иногда в этом процессе участвовали несколько жилых IP-адресов и использовались неправдоподобные сочетания браузера и операционной системы.

При некоторых попытках аутентификации возникала ошибка Microsoft Entra 90014, связанная с отсутствием параметра nonce в протоколе OAuth. Это крайне редкое явление для собственного приложения OfficeHome.

Для Python Pirates, злоупотребляют Microsoft Graph



Наиболее устойчивый сигнал появился после компрометации. Roughly 11 to 24 hours after initial access, attackers began refreshing stolen sessions at approximately eight-hour intervals.

The official Microsoft 365 login page is proxied through an AiTM-generated page (Source : Arctic wolf).

These sign-ins retained the same SessionID but originated from changing IP addresses, ASNs, and locations.

They also frequently claimed to use Outlook while presenting anomalous Firefox or Python Requests user agents instead of expected Microsoft client behavior.

The **operators then pivoted to Microsoft Graph** reconnaissance, enumerating tenant users associated with finance, payroll, HR, administrative, and payment

In Defender XDR, this generated “Suspicious Exchange Online Graph Reconnaissance Activity” alerts, often using the axios/1.18.1 user agent.

Across three separate tenant environments, malicious MailItemsAccessed activity occurred within the same 26-second collection window (Source : Arctic wolf).

The actors subsequently accessed mailbox content relating to payroll, invoices, payments, banking, benefits, and internal documentation.

Cross-tenant mailbox collection occurred in tightly synchronized bursts, suggesting centralized automation rather than isolated manual activity.

Most intrusions avoided conventional business email compromise behavior such as MFA changes, password resets, device registration, outbound phishing, and inbox-rule creation.

That restraint reduces obvious detection opportunities while preserving long-term access to financially valuable communications.

Defenders should correlate phishing telemetry with Entra sign-ins, SessionID reuse, residential-proxy rotation, anomalous Outlook user agents, Graph reconnaissance, and MailItemsAccessed events.

Detecting the complete behavioral chain is more reliable than relying on a malicious domain, a single IP address, or a single authentication anomaly.

**Why use the 2026 Agentic SOC Buyer's Guide? 8 Best Platforms
Compared – [Download the 2026 Buyer's Guide](#)**